Repositories & Tools

Vulnerable: OWASP Juice Shop https://github.com/Marwan123-web/juice-shop

Clean: Sports-Web (tournaments/booking backend) https://github.com/Marwan123-web/sports-web

SAST: SonarCloud | SCA: OWASP Dependency-Check

Made with GAMMA

Juice Shop Overview

Deliberately insecure Node.js e-commerce (OWASP Top 10).

Why: Known vulns (injections, XSS, auth bypass); benchmark for tool accuracy.

Made with GAMMA

Sports-Web Overview

Personal Node.js/Express backend for sports app (tournaments, fields booking).

Why: No public advisories/CVEs; tests real-world clean code.

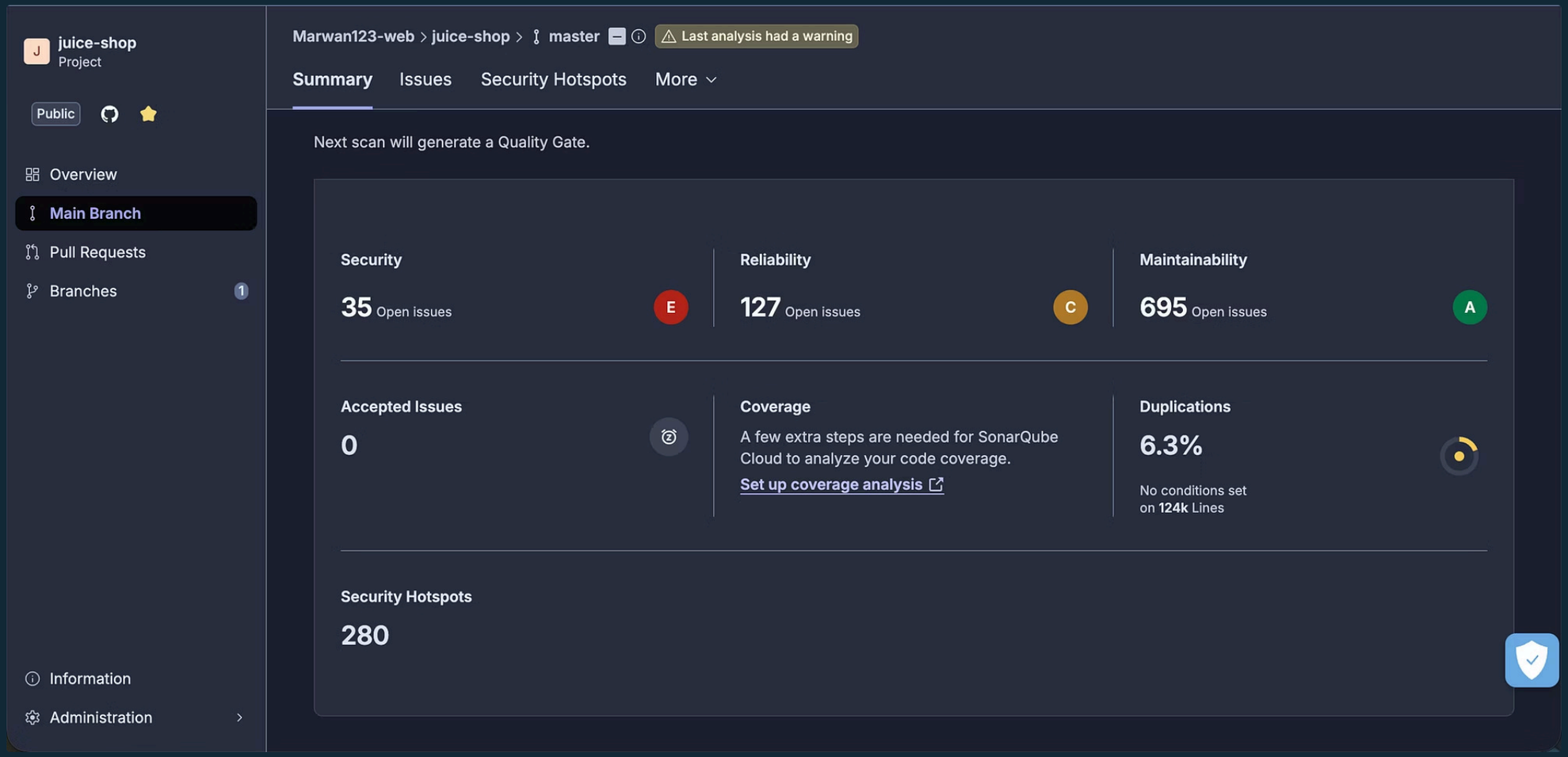
Made with GAMMA

Juice Shop SAST

35 Security Issues

280 Hotspots

Ex: Dynamic injection eval(), hard-coded pwds.



Made with GAMMA

Juice Shop SCA

1

23 Vulnerable Components

2

4 Critical

3

12 High

Ex: helmet, express CVEs (DoS, injection).

Summary

Display: Showing Vulnerable Dependencies (click to show all)

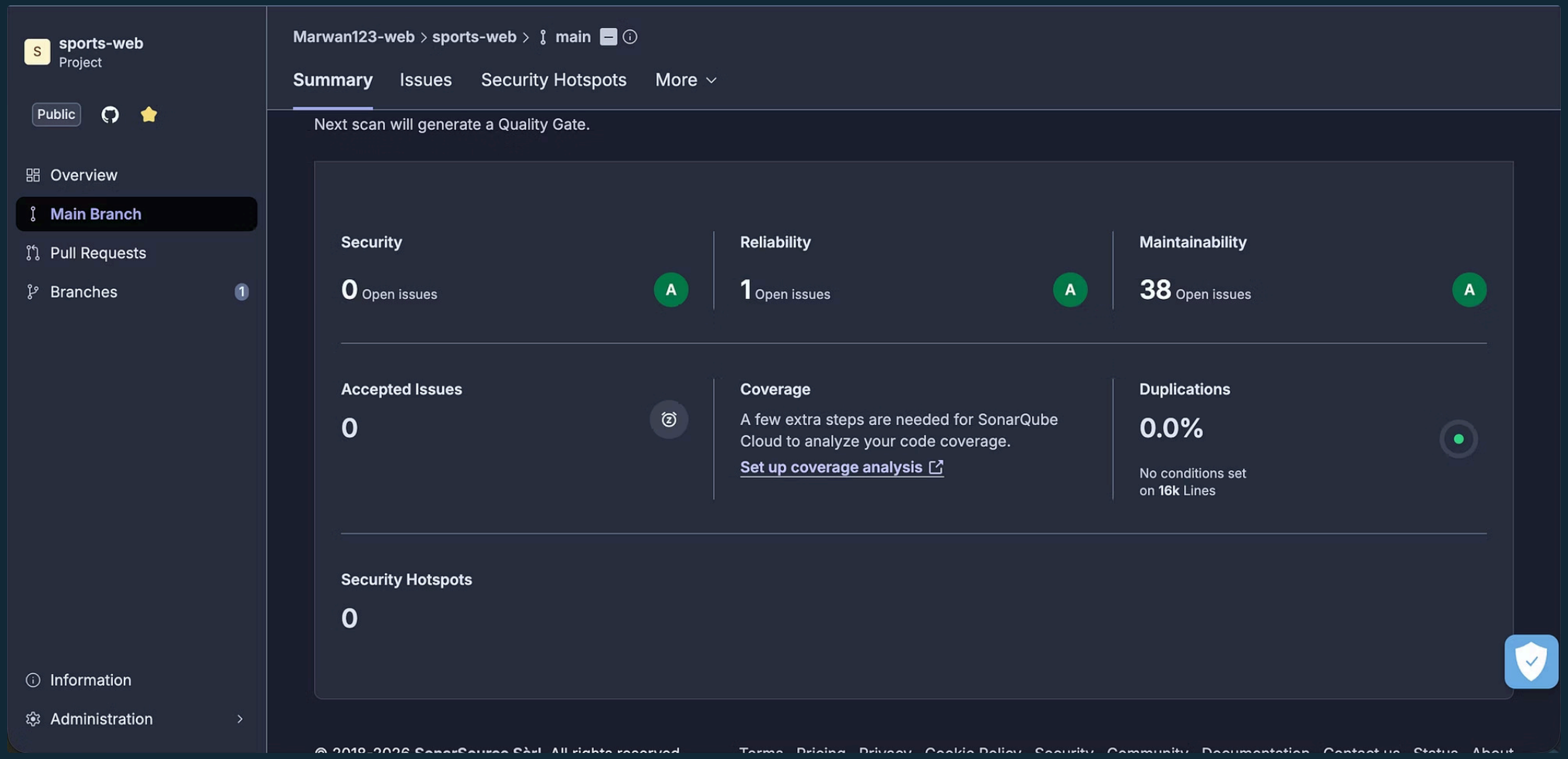
Dependency	Vulnerability IDs	Package	Highest Severity	CVE Count	Confidence	Evidence Count
bench.js		pkg:javascript/underscore.js@1.7.0	HIGH	1		3
blaze.jar (shaded: commons-io:commons-io:2.4)	cpe:2.3:a:apache:commons_io:2.4:*:*:*:*:*:*:*	pkg:maven/commons-io/commons-io@2.4	MEDIUM	2	Highest	86
blaze.jar	cpe:2.3:a:apache:ivy:0.8.0:*:*:*:*:*:*:*		HIGH	1	Low	14
commons-beanutils-1.9.4.jar	cpe:2.3:a:apache:commons_beanutils:1.9.4:*:*:*:*:*:*:*	pkg:maven/commons-beanutils/commons-beanutils@1.9.4	HIGH	1	Highest	167
commons-lang3-3.17.0.jar	cpe:2.3:a:apache:commons_lang:3.17.0:*:*:*:*:*:*:*	pkg:maven/org.apache.commons/commons-lang3@3.17.0	MEDIUM	1	Highest	144
express-jwt:0.1.3	cpe:2.3:a:auth0:express-jwt:0.1.3:*:*:*:*:*:*:*	pkg:npm/express-jwt@0.1.3	CRITICAL	1	Highest	9
httpclient5-5.4.2.jar	cpe:2.3:a:apache:httpclient:5.4.2:*:*:*:*:*:*:*	pkg:maven/org.apache.httpcomponents.client5/httpclient5@5.4.2	HIGH	1	Highest	29
js-yaml:3.14.2	cpe:2.3:a:nodeca:js-yaml:3.14.2:*:*:*:*:*:*:*	pkg:npm/js-yaml@3.14.2	MEDIUM	1	Highest	7
jsonwebtoken:0.4.0	cpe:2.3:a:auth0:jsonwebtoken:0.4.0:*:*:*:*:*:*:*	pkg:npm/jsonwebtoken@0.4.0	CRITICAL	4	Highest	7
lodash.js		pkg:javascript/lodash@2.4.2	CRITICAL	4		3
lodash.js		pkg:javascript/lodash@2.4.2	CRITICAL	4		3
lodash.min.js		pkg:javascript/lodash@2.4.2	CRITICAL	4		3
moment.js		pkg:javascript/moment.js@2.0.0	HIGH	4		3
moment.min.js		pkg:javascript/moment.js@2.0.0	HIGH	4		3
notevil:1.3.3	cpe:2.3:a:notevil_project:notevil:1.3.3:*:*:*:*:*:*:*	pkg:npm/notevil@1.3.3	MEDIUM	1	Highest	7

Made with GAMMA

Sports-Web SAST

0 Security Issues/Hotspots ✅

38 Maintainability (minor dupls/unchanged funcs).



Made with GAMMA

Sports-Web SCA

11 Vulns total (1 High: express-validator CVE)

Mostly Medium/Low; actionable updates.

Project:

Scan Information (show less):

- *dependency-check version*: 12.1.0
- *Report Generated On*: Sat, 10 Jan 2026 19:18:43 +0100
- *Dependencies Scanned*: 17528 (12474 unique)
- *Vulnerable Dependencies*: 8
- *Vulnerabilities Found*: 9
- *Vulnerabilities Suppressed*: 0
- *NVD API Last Checked*: 2026-01-10T19:17:51+01
- *NVD API Last Modified*: 2026-01-10T15:15:50Z

Summary

Display: Showing Vulnerable Dependencies (click to show all)

Dependency	Vulnerability IDs	Package	Highest Severity	CVE Count	Confidence	Evidence Count
body-parser:2.2.0		pkg:npm/body-parser@2.2.0	MEDIUM	1		5
commons-beanutils-1.9.4.jar	cpe:2.3:a:apache:commons_beanutils:1.9.4:*:*:*:*:*:*:*	pkg:maven/commons-beanutils/commons-beanutils@1.9.4	HIGH	1	Highest	167
commons-lang3-3.17.0.jar	cpe:2.3:a:apache:commons_lang:3.17.0:*:*:*:*:*:*:*	pkg:maven/org.apache.commons/commons-lang3@3.17.0	MEDIUM	1	Highest	144
httpclient5-5.4.2.jar	cpe:2.3:a:apache:httpclient:5.4.2:*:*:*:*:*:*:*	pkg:maven/org.apache.httpcomponents.client5/httpclient5@5.4.2	HIGH	1	Highest	29
js-yaml:3.14.1	cpe:2.3:a:nodeca:js-yaml:3.14.1:*:*:*:*:*:*:*	pkg:npm/js-yaml@3.14.1	MEDIUM	1	Highest	7
jws:3.2.2		pkg:npm/jws@3.2.2	HIGH	1		6
qs:6.14.0	cpe:2.3:a:qs_project:qs:6.14.0:*:*:*:*:*:*:*	pkg:npm/qs@6.14.0	HIGH	1	Highest	6
validator:13.15.20	cpe:2.3:a:validator_project:validator:13.15.20:*:*:*:*:*:*:*	pkg:npm/validator@13.15.20	HIGH	2	Highest	8

Made with GAMMA

Key Findings

Aspect	Juice Shop	Sports-Web
SAST Vulns	35+280	0
SCA Critical/High	16	1 High

SAST: Catches code vulns (injections).

SCA: Supply chain risks (even "clean" code).

Made with GAMMA

False Pos/Neg Examples

- Juice Shop FP: None obvious (expected vulns).
- Sports-Web FN?: SCA High in validator—review if real (semver range).

Lessons: No silver bullet; manual review essential.

Made with GAMMA

Lessons Learned

- SAST strong on taint analysis (Juice Shop injections).
- SCA essential for deps (Sports-Web still had 11).
- Clean code = fewer code vulns, but deps always risky.
- Tools complement; update deps + code review.

Made with GAMMA